

Manual de Segurança da Informação

Site de Jogos: Moonlight

Última atualização: 27/08/2025

Este manual tem como objetivo estabelecer diretrizes e práticas de segurança da informação para proteger os dados, sistemas e usuários do site **Moonlight** contra acessos não autorizados, vazamentos, fraudes, ataques cibernéticos e outras ameaças digitais.

- **Confidencialidade:** Garantir que os dados dos usuários e do sistema não sejam acessados por pessoas não autorizadas.
- **Integridade:** Garantir que os dados não sejam alterados de forma indevida.
- **Disponibilidade:** Garantir que os serviços e informações estejam acessíveis quando necessário.
- **Autenticidade:** Verificar a identidade dos usuários e sistemas que acessam os recursos.
- **Responsabilidade:** Atribuir e registrar ações feitas por usuários ou administradores.
- **2.1 Cadastro e Login**
 - Utilização obrigatória de **senhas fortes** (mínimo 8 caracteres, letras maiúsculas/minúsculas, números e símbolos).
 - Implementar **autenticação de dois fatores (2FA)** para contas de administradores e usuários VIP.
 - Bloquear contas temporariamente após tentativas de login falhas consecutivas.

2.2 Privacidade de Dados

- Informar ao usuário sobre coleta, uso e armazenamento de dados através de uma **Política de Privacidade** clara e acessível.
- Armazenar senhas de forma segura usando **hashing com sal** (ex: bcrypt, Argon2).
- Oferecer opção de exclusão de conta e dados pessoais conforme LGPD.

3.1 Servidor e Infraestrutura

- Usar **HTTPS** com certificado TLS válido em todo o site.
- Manter servidores e bibliotecas **atualizados** com os últimos patches de segurança.
- Implementar **firewalls** e ferramentas de monitoramento de tráfego.
- Realizar **backups regulares** em local seguro e testado periodicamente.

3.2 Proteções contra Ataques

- Proteger contra **injeção de SQL, XSS, CSRF, LFI/RFI**, e outros ataques comuns.
- Limitar requisições (rate limiting) para evitar **ataques de força bruta e DDoS**.
- Utilizar WAF (Web Application Firewall) para proteger a aplicação web.

3.3 Gerenciamento de Sessões

- Sessões expiram após um período de inatividade.
 - Cookies de sessão marcados como **HttpOnly** e **Secure**.
 - Revogação de tokens ao deslogar.
 - Usar **repositórios privados** para o código-fonte.
 - Utilizar ferramentas de **análise de vulnerabilidades** no ciclo de desenvolvimento.
 - Aplicar o princípio de **menor privilégio**: desenvolvedores não devem ter acesso a dados sensíveis de produção.
 - Controlar acesso por ambiente (ex: produção, staging, desenvolvimento).
-
- Monitorar e mitigar **trapaças e exploits** usando ferramentas anti-cheat.
 - Proteger contra manipulação de pacotes e engenharia reversa.
 - Validar ações do cliente no servidor para garantir integridade do jogo.
-
- Estar em conformidade com:
 - **LGPD** (Lei Geral de Proteção de Dados – Brasil).
 - **GDPR** (se tiver usuários da União Europeia).
 - Coletar **consentimento explícito** do usuário para uso de cookies e dados pessoais.
 - Manter um canal de contato para solicitações sobre dados pessoais.

- Em caso de incidente de segurança:
 - Notificar os administradores imediatamente.
 - Avaliar o impacto e isolar o incidente.
 - Notificar os usuários afetados, se necessário.
 - Documentar o ocorrido para auditoria e melhoria contínua.
- Desenvolvedores e equipe técnica devem receber **treinamento periódico** sobre segurança.
- Promover campanhas de **conscientização de segurança** com os usuários, como:
 - Dicas de criação de senhas seguras.
 - Alertas sobre phishing ou golpes comuns.
- **Cloudflare / AWS Shield** – Proteção contra DDoS.
- **OWASP ZAP** ou **Burp Suite** – Testes de segurança.
- **Let's Encrypt** – Certificado SSL gratuito.
- **Snyk / Dependabot** – Detecção de vulnerabilidades em dependências.

Este manual deve ser revisado e atualizado:

- A cada **6 meses**.
- Após incidentes de segurança.
- Quando houver mudanças significativas na infraestrutura ou legislação.